

LVChat

Full Monty Audit Report

0 CRITICAL · 1 HIGH · 2 MEDIUM · 0 LOW

Generated: August 12, 2026 at 02:15 PM
Scope: FULL_MONTY
Total findings: 3 · Security: 2 · Performance: 0 · UI/UX: 1

Executive Summary

Metric	Value
Total Findings	3
Critical Severity	0
High Severity	1
Medium Severity	2
Low Severity	0
---	---
Security findings	2
Performance findings	0
UI/UX findings	1
---	---
GPT-OSS-20b findings	0
MiniMax/grep findings	2

Methodology

Security scan (Step 2.5): Two-model parallel approach. Model A — GPT-OSS-20b at 192.168.8.147:1234 (Botbox2): static per-file security review using a 6-thread worker pattern. Model B — MiniMax + local grep sweep: regex/heuristic pass over all source files. Vulnerability classes scanned: SQLi, XSS, CSRF, IDOR,

AuthBypass, HardcodedSecret, SessionHardening, FileUpload/PathTraversal, TimingAttack, Cron/TOCTOU, InfoDisclosure, InsecureDeserialization, OpenRedirect, MissingRateLimit, CORS/OriginCheck, HeaderInjection.

Performance scan (Step 2.6): Same two-model pattern. Classes scanned: N+1, MissingIndex, UnboundedResultSet, SyncExternalCall, MissingCache, AssetBloat, RenderBlocking, ExcessiveDOM, MemoryHotPath, ResourceLeaks, CronInefficiency, ColdStart, FrontendRuntime, NetworkPayload, ConnectionPool, Concurrency.

UI/UX scan (Step 2.7): Same two-model pattern plus Playwright screenshot review where available. Classes scanned: a11y, FormUX, LoadingStates, ErrorUX, InformationArchitecture, VisualConsistency, ResponsiveDesign, i18n, StateFeedback, Discoverability, NativeDialog, DataBinding, DeadUI, ColorContrast, Microcopy, Motion, PrintExport.

Severity scale: Critical (direct exploit / unusability) → High (realistic exploit / visible breakage) → Medium (preconditions / tolerable lag) → Low (defense-in-depth / polish).

Scope rule (CRITICAL): *install/*, *e2e/*, and *tests/* directories are excluded from live-code audit scope. They are development-only and must never reach production. These folders should be manually deleted before any upload.

Security Findings

2 finding(s): 0 Critical · 1 High · 1 Medium · 0 Low

H-02	HIGH	BrokenAccessControl	manual audit of bin/ws-server.php + regression test
File : Line	bin/ws-server.php : 312		
Vulnerable Code	case 'subscribe': if (!empty(\$msg['channel'])) { \$st['sub'] = ['type' => 'channel', 'target' => (string) \$msg[...		
Description	WS-mode realtime authorization gap: the Workerman gateway accepted a subscribe for ANY channel slug or DM username fr		
Remediation	(1) Channel subscriptions authorized at subscribe time via AccessService::member(). (2) DM fan-out authorized at broadcast t		

H-01	MEDIUM	SessionFixation	test suite output + grep sweep
File : Line	src/Auth.php : 195		
Vulnerable Code	session_regenerate_id(true);		
Description	session_regenerate_id() called after headers already sent in CLI/test context, emitting PHP Warning. Line 173 had @ suppress		
Remediation	Added @ error suppression to session_regenerate_id() at src/Auth.php:195 and src/controllers/AuthController.php:88, matchin		

UI/UX Findings

1 finding(s): 0 Critical · 0 High · 1 Medium · 0 Low

U-02	MEDIUM	NativeDialog	grep sweep across views/ + throwaway Electron e2e
File : Line	views/admin/* + views/user/profile.php : 0		
Vulnerable Code	onsubmit="return confirm('...') / var reason = prompt(msg, ") / alert(j.error)		
Description	Native dialog abuse: 34 window.confirm()/prompt()/alert() call sites across the admin views and the user profile page, while the		
Remediation	Added public/assets/js/dialog.js — a self-contained styled-modal LVCDialog (confirm/prompt/alert, promise-based) plus a data		